

Email Security Policies and Compliance

Acceptable use, encryption, authentication, retention, and regulatory framework

Deliverable 6 of 6

Table of Contents

1. Purpose and Scope
2. Acceptable Use Policy
3. Encryption Policy
4. Authentication Policy
5. Email Retention Policy
6. Incident Response Procedures
7. Compliance Framework
8. Enforcement and Consequences
9. Review and Updates

1. Purpose and Scope

This policy defines the rules governing email use, security controls, and incident handling for the consulting firm. It applies to all employees, contractors, consultants, interns, and any third party with access to the corporate email system.

The policy is effective from the date of approval and remains in force until formally revised. All staff must read and acknowledge the policy at onboarding and after every annual revision.

2. Acceptable Use Policy

2.1 Permitted Uses

- Communication directly related to job responsibilities
- Limited personal use, as long as it does not impact work or breach other policies
- Business correspondence with clients, partners, and vendors

2.2 Prohibited Activities

- Transmitting confidential or proprietary information without proper encryption
- Sending or forwarding harassing, discriminatory, or offensive content
- Using corporate email for political campaigning or commercial side-businesses
- Forwarding company email to personal accounts (Gmail, Yahoo, etc.) for any reason
- Auto-forwarding rules to external addresses without security approval
- Subscribing to non-business mailing lists from corporate addresses

3. Encryption Policy

3.1 Mandatory Encryption

Encryption is mandatory for any email containing the following:

- Client personally identifiable information (PII)
- Financial data including invoices, billing, or banking details
- Health information or other special category data under GDPR
- Internal commercial information marked CONFIDENTIAL or RESTRICTED
- Authentication credentials of any kind (passwords, API tokens, etc.)

3.2 Approved Tools

- PGP/OpenPGP - primary tool for technical staff and internal communications
- S/MIME with Actalis or DigiCert certificates - for executive and client-facing communications
- Other encryption tools require written approval from the Information Security team

3.3 Key Management

- Private keys are personal to each user and must never be shared
- Strong passphrases (12+ characters) must protect private keys
- Keys are rotated every 12-24 months as part of normal hygiene
- Revocation certificates must be generated at key creation and stored offline

4. Authentication Policy

4.1 Passwords

- Minimum length: 12 characters
- Must contain a mix of uppercase, lowercase, numbers, and symbols
- Cannot be reused from any previous password on company systems
- Cannot match patterns common to the user (name, birthdate, etc.)
- Rotate every 90 days for privileged accounts

4.2 Multi-Factor Authentication

- MFA is mandatory for all corporate email accounts without exception
- Authenticator apps are required (Google Authenticator, Microsoft Authenticator, Authy)
- SMS-based MFA is not permitted due to SIM-swap risk
- Hardware security keys recommended for executives and privileged users

4.3 Account Lockout

- Accounts are locked after 5 consecutive failed login attempts
- Unlock requires identity verification through the IT helpdesk
- Idle session timeout is enforced at 30 minutes

5. Email Retention Policy

- Standard retention period: 7 years from the date of original send/receive
- Legal hold notices override retention - flagged mails are kept indefinitely until released
- Personal emails (within the permitted personal use limit) may be deleted at user's discretion
- Daily backups of all email stores, retained for 30 days online and 1 year offline
- After retention period expires, emails are securely deleted using approved sanitisation methods

6. Incident Response Procedures

6.1 Phishing Reports

- Suspected phishing emails must be forwarded to phishing@consultingfirm.com
- Do not click links or open attachments under any circumstances
- The Information Security team will analyse the message and notify all staff if it is a widespread campaign

6.2 Account Compromise

- Immediate password reset and revocation of all active sessions
- Review of mailbox rules, forwarding settings, and delegated access
- Audit of recent sent items for any malicious activity
- Notification to affected clients if their data was exposed

6.3 Data Breach via Email

- Chief Information Security Officer must be notified within 1 hour of discovery
- Affected data subjects notified within 72 hours per GDPR requirements
- Regulators notified per applicable law (CERT-In, ICO, etc.)
- Post-incident review conducted within 14 days, with corrective actions documented

7. Compliance Framework

7.1 GDPR (European Data Subjects)

Where the consulting firm processes personal data of European Union residents, the General Data Protection Regulation applies. Email systems must support the data subject rights of access, rectification, erasure, restriction, and portability. Encryption of personal data in transit is treated as a recommended technical safeguard. Breach notifications to the supervisory authority must be made within 72 hours of discovery.

7.2 HIPAA (Healthcare Clients)

When dealing with healthcare clients, the Health Insurance Portability and Accountability Act applies in the United States. Protected Health Information (PHI) communicated via email must be encrypted both in transit and at rest. Audit logs must capture all access to email systems containing PHI. Business Associate Agreements are required with any third-party email provider handling PHI.

7.3 Indian IT Act 2000

In India, the Information Technology Act 2000 and the SPDI Rules under it require reasonable security practices for handling sensitive personal data. Section 43A provides for compensation when failures in data protection cause loss. The consulting firm must demonstrate reasonable security practices, of which encryption of sensitive personal data is one widely recognised example.

7.4 Industry-Specific Add-ons

- PCI DSS - when handling payment card data, all email containing cardholder data must be encrypted
- RBI guidelines - applicable when communicating with banking sector clients
- SEBI - applicable for listed-company communications

8. Enforcement and Consequences

Violation Level	Consequence
First Offence	Written warning and mandatory remedial training
Second Offence	Formal disciplinary action recorded in employee file
Third Offence	Suspension or termination depending on severity
Criminal Activity	Reported to law enforcement, immediate termination, civil action as appropriate

9. Review and Updates

- Annual review by the Information Security Committee
- Out-of-cycle updates triggered by significant incidents or regulatory changes
- All staff notified of policy updates via email and intranet
- Acknowledgement signature required from all staff after each material change
- Version history maintained with change rationale documented